

Informe de Gestión de Riesgos

Presentación al Directorio

Septiembre 2026 | Extraído de plataforma SimpleRisk

Resumen Ejecutivo

A raíz de los hallazgos de la última auditoría externa, se llevó a cabo una evaluación integral de los activos de información de la clínica. Considerando nuestra infraestructura que da soporte a 120 empleados y procesa datos de 800 pacientes diarios, se han identificado y cargado 7 riesgos formales en la plataforma. La vulnerabilidad principal radica en los accesos genéricos a historias clínicas y la falta de alta disponibilidad en los servidores. Para abordar las amenazas más críticas, se han planificado 3 iniciativas estratégicas orientadas a mitigar riesgos legales y tecnológicos de forma inmediata.

Top 5 Riesgos por Nivel de Criticidad

ID	Descripción del Riesgo	Prob × Imp	Nivel
R01	Acceso indebido a expedientes electrónicos por personal no médico	4 × 5 = 20	Crítico
R07	Incumplimiento normativo de la Ley de Protección de Datos	4 × 4 = 16	Crítico
R02	Interrupción del sistema de historias clínicas (falla de servidor)	3 × 5 = 15	Alto
R06	Infección por ransomware por falta de gestión de parches	3 × 5 = 15	Alto
R05	Compromiso de credenciales por ataques de phishing al personal	4 × 3 = 12	Alto

Estado de los Planes de Acción

Actualmente, se han formalizado tres estrategias de mitigación en estado de planificación (*Planning*), enfocadas en reducir drásticamente la exposición de los riesgos de mayor impacto:

Iniciativa (Solución Planeada)	Riesgo	Vencimiento	Presupuesto
Implementación de Control de Accesos Basado en Roles (RBAC)	R01	10/12/2026	\$1,200 USD
Alta Disponibilidad y RespalDOS Automatizados en la Nube	R02	30/10/2026	\$4,500 USD
Despliegue de Gestión de Parches y Antivirus EDR	R06	15/11/2026	\$2,100 USD

Recomendaciones Prioritarias

- **Ejecutar el Plan de Control de Accesos (RBAC):** Es imperativo restringir la visualización de las historias clínicas de los 800 pacientes diarios únicamente al personal médico autorizado, limitando al sector administrativo a tareas de facturación para evitar sanciones.
- **Aprobar presupuesto para infraestructura de respaldo:** La clínica no puede permitirse la caída del servidor principal. La adquisición del equipo secundario y los backups automatizados garantizan la continuidad de atención en consultorios.
- **Asegurar las estaciones de trabajo:** Implementar el software EDR y la actualización de parches en las 120 computadoras previene infecciones por ransomware que podrían encriptar nuestra base de datos.
- **Desarrollar un plan de concientización:** Programar capacitaciones obligatorias contra el *phishing* para todo el personal médico y administrativo.